

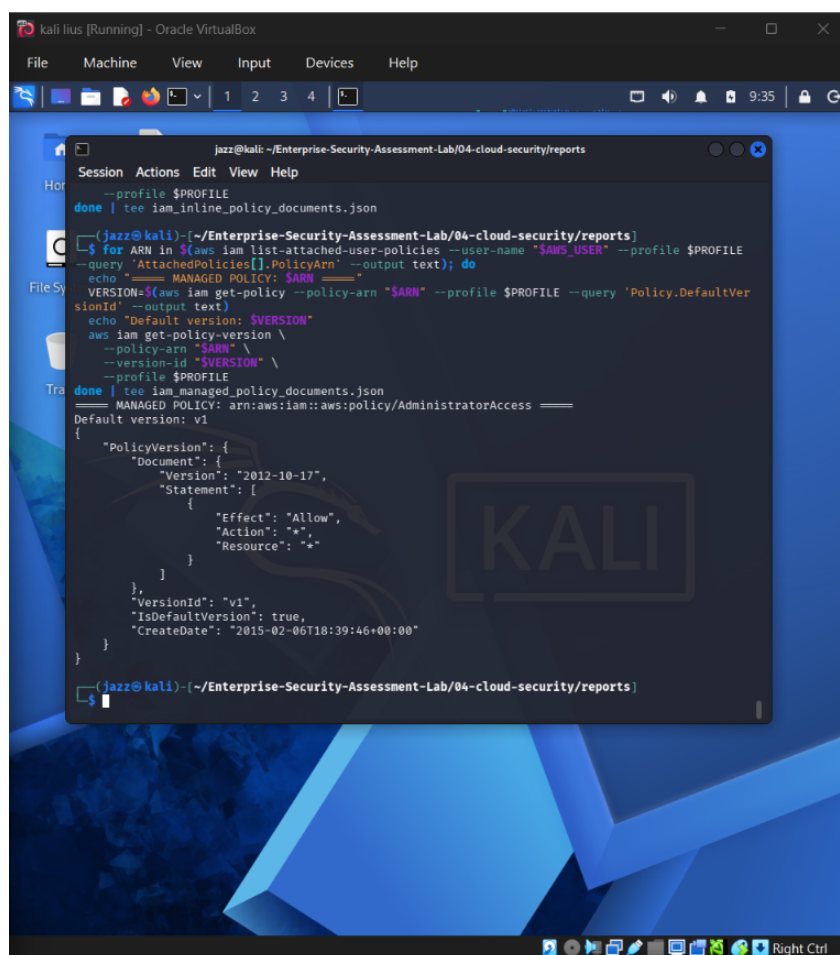
CLOUD SECURITY EVIDENCE REPORT

IAM PERMISSIONS ENUMERATION

Project	Enterprise Security Assessment Lab
Module	04 - Cloud Security
Evidence File	iam-permissions-enumeration.png
Report File	01-iam-permissions-enumeration-evidence-report.pdf
Result Type	IAM identity and policy review
Environment	AWS CloudGoat / AWS CLI / Pacu / ScoutSuite / Local Kali Lab
Publication Status	GitHub-ready portfolio report with sensitive values redacted

This document is an evidence-specific professional report. It explains one screenshot from the Cloud Security module, maps it to the testing methodology, interprets the tool output, and documents real-world risk, remediation and redaction requirements.

1. Embedded Evidence Screenshot



```
jazz@kali: ~/Enterprise-Security-Assessment-Lab/04-cloud-security/reports
--profile $PROFILE
done | tee iam_inline_policy_documents.json

(jazz@kali)~/Enterprise-Security-Assessment-Lab/04-cloud-security/reports
$ for ARN in $(aws iam list-attached-user-policies --user-name $AWS_USER --profile $PROFILE
--query 'AttachedPolicies[].PolicyArn' --output text); do
echo "===== MANAGED POLICY: $ARN ====="
VERSION=$(aws iam get-policy --policy-arn $ARN --profile $PROFILE --query 'Policy.DefaultVer
sionId' --output text)
echo "Default version: $VERSION"
aws iam get-policy-version \
--policy-arn $ARN \
--version-id $VERSION \
--profile $PROFILE
done | tee iam_managed_policy_documents.json
===== MANAGED POLICY: arn:aws:iam::aws:policy/AdministratorAccess =====
Default version: v1
{
  "PolicyVersion": {
    "Document": {
      "Version": "2012-10-17",
      "Statement": [
        {
          "Effect": "Allow",
          "Action": "*",
          "Resource": "*"
        }
      ]
    },
    "VersionId": "v1",
    "IsDefaultVersion": true,
    "CreateDate": "2015-02-06T18:39:46+00:00"
  }
}
```

Figure 1 - Redacted evidence screenshot: iam-permissions-enumeration.png

What this screenshot proves

The terminal evidence shows IAM policy enumeration from the lab profile. A managed policy document is displayed, including an allow statement with broad actions/resources as part of the intentionally vulnerable lab scenario.

2. Evidence Context

Testing Phase	Cloud Identity and Access Review
Tool / Component	AWS CLI / IAM Policy Enumeration
Objective	Confirm which IAM policies are attached to the current lab principal and review whether broad or risky permissions exist in the AWS CloudGoat environment.

Result Type	IAM identity and policy review
Evidence Source	iam-permissions-enumeration.png

3. Command / Workflow Used

The following sanitized workflow represents the command pattern or console path used for this evidence. Live identifiers, account values, tokens and credentials are intentionally replaced with placeholders.

```
aws sts get-caller-identity --profile <LAB_PROFILE>

for ARN in $(aws iam list-attached-user-policies --user-name <LAB_USER> --profile <LAB_PROFILE>
--query 'AttachedPolicies[].PolicyArn' --output text); do
VERSION=$(aws iam get-policy --policy-arn "$ARN" --profile <LAB_PROFILE> --query
'Policy.DefaultVersionId' --output text)
aws iam get-policy-version --policy-arn "$ARN" --version-id "$VERSION" --profile <LAB_PROFILE>
done
```

4. Sanitized Output Interpretation

The terminal evidence shows IAM policy enumeration from the lab profile. A managed policy document is displayed, including an allow statement with broad actions/resources as part of the intentionally vulnerable lab scenario.

The goal of this evidence is not simply to show that a tool was executed. It demonstrates that the tool output was reviewed and interpreted as part of a controlled cloud security assessment. In a professional assessment, raw tool output must always be converted into a clear technical explanation, business risk statement and remediation plan.

5. Security Impact and Risk Analysis

Overly broad IAM permissions can create privilege escalation paths, enable unauthorized resource creation, or allow attackers to attach or modify policies after compromising a low-privileged identity.

In a real cloud environment, the practical risk depends on the permissions of the identity, exposed services, network context, logging coverage and business sensitivity of the affected resources. This report treats the evidence as a lab finding but explains the likely real-world impact if the same condition existed in production.

MITRE / Control Mapping	T1078.004 - Valid Accounts: Cloud Accounts / T1538 - Cloud Service Dashboard / Permission Discovery
-------------------------	---

Impact Area	Identity security, cloud configuration, exposure management and operational governance
Portfolio Value	Shows tool execution, interpretation, redaction discipline and professional reporting maturity

6. Recommended Remediation

- Apply least privilege to every IAM user and role.
- Avoid wildcard actions and wildcard resources unless strictly justified.
- Use IAM Access Analyzer and regular policy reviews.
- Restrict iam:PassRole, iam:AttachUserPolicy, iam:PutUserPolicy and similar high-risk actions.
- Use permission boundaries for lab and developer identities.

7. GitHub Redaction and Publication Guidance

Cloud account identifiers, access keys, secret keys and session tokens must not be published. This evidence does not expose active secrets, but the report uses sanitized placeholders for commands.

Before committing any cloud evidence to GitHub, review the screenshot for AWS account IDs, ARNs, IAM usernames, bucket names, EC2 instance IDs, access keys, secret keys, session tokens, Azure subscription identifiers, public IP addresses, billing details and local private paths. If any of those values are present, redact or blur them before upload.

Recommended GitHub folder	04-cloud-security/reports/evidence/
Report link format	./reports/evidence/01-iam-permissions-enumeration-evidence-report.pdf
Evidence screenshot folder	04-cloud-security/screenshots/